(Dis)patches from the WebPKI

Fina, Static CT, MTC, and PLANTS

Luke Valenta (Cloudflare), David Benjamin (Google), Matthew McPherrin (Let's Encrypt), Filippo Valsorda (Geomys)
RWC 2026

This talk

What’s been happening in the WebPKI.

This talk

What’s been happening in the WebPKI.

Special focus on Merkle Tree Certificates.

- Fast, quantum-safe certs

This talk

What's been happening in the WebPKI.

Special focus on Merkle Tree Certificates.

- Fast, quantum-safe certs

And why you should care.

- Standardization efforts are underway at IETF
- Chrome to *only* support MTCs in new quantum-resistant root program
- Major CAs are interested
- Large-scale MTC feasibility study is ongoing
  - Early results (this talk)

Not just browsers.

- Ubuntu upki project opening a path for MTCs in Linux

The Internet is a series of ~~tubes~~patches

The Internet is a series of ~~tubes~~patches

1980s: Wild west 🤠

- No widespread authentication/encryption: Need to send sensitive data? YOLO!

The Internet is a series of ~~tubes~~patches

1980s: Wild west 🤠

- No widespread authentication/encryption: Need to send sensitive data? YOLO!

1995: 🩹 SSL/TLS 🔒 (e-commerce 💰)

- Certification Authorities (CAs) issue certificates to attest to “domain ⇔ pubkey” claims
- Soon, 100+ trusted CAs in client root stores
- … maybe we shouldn’t blindly trust them all? (2011 DigiNotar incident)

The Internet is a series of ~~tubes~~patches

1980s: Wild west 🤠

- No widespread authentication/encryption: Need to send sensitive data? YOLO!

1995: 🩹 SSL/TLS 🔒 (e-commerce 💰)

- Certification Authorities (CAs) issue certificates to attest to “domain ⇔ pubkey” claims
- Soon, 100+ trusted CAs in client root stores
- … maybe we shouldn’t blindly trust them all? (2011 DigiNotar incident)

2013: 🩹 Certificate Transparency (CT) ✨ (Levchin prize winner, RWC 2024)

- Trust but verify: every cert issued by public CAs must be publicly auditable
- CT still matters: 2025 Fina CA mis-issuance of 1.1.1.1 certificates only detected with CT
- … but, running CT logs reliably is expensive and hard

The Internet is a series of ~~tubes~~patches

1980s: Wild west 🤠

- No widespread authentication/encryption: Need to send sensitive data? YOLO!

1995: 🩹 SSL/TLS 🔒 (e-commerce 💰)

- Certification Authorities (CAs) issue certificates to attest to “domain ⇔ pubkey” claims
- Soon, 100+ trusted CAs in client root stores
- … maybe we shouldn’t blindly trust them all? (2011 DigiNotar incident)

2013: 🩹 Certificate Transparency (CT) ✨ (Levchin prize winner, RWC 2024)

- Trust but verify: every cert issued by public CAs must be publicly auditable
- CT still matters: 2025 Fina CA mis-issuance of 1.1.1.1 certificates only detected with CT
- … but, running CT logs reliably is expensive and hard

2024: 🩹 Static CT 🌞 (Filippo Valsorda, “Modern transparency logs”, RWC 2024)

- Log data served as static, cacheable assets
- Makes running CT logs cheaper and easier: already significant support in the CT ecosystem
- … but, upcoming changes will make running CT-based PKIs even harder

Shorter certificate lifetimes

By 2029, the maximum TLS certificate lifetime will be 47 days (from 398 today)

Shorter certificate lifetimes

By 2029, the maximum TLS certificate lifetime will be 47 days (from 398 today)

Impact for TLS

- Smaller blast radius for compromised certificate keys ✅
- More incentive to invest in automated certificate management 🤖

Shorter certificate lifetimes

By 2029, the maximum TLS certificate lifetime will be 47 days (from 398 today)

Impact for TLS

- Smaller blast radius for compromised certificate keys ✅
- More incentive to invest in automated certificate management 🤖

Impact for CT

- Certificate issuance volume will go up 📈
- CT logs will log more entries 📈

Shorter certificate lifetimes

By 2029, the maximum TLS certificate lifetime will be 47 days (from 398 today)

Impact for TLS

- Smaller blast radius for compromised certificate keys ✅
- More incentive to invest in automated certificate management 🤖

Impact for CT

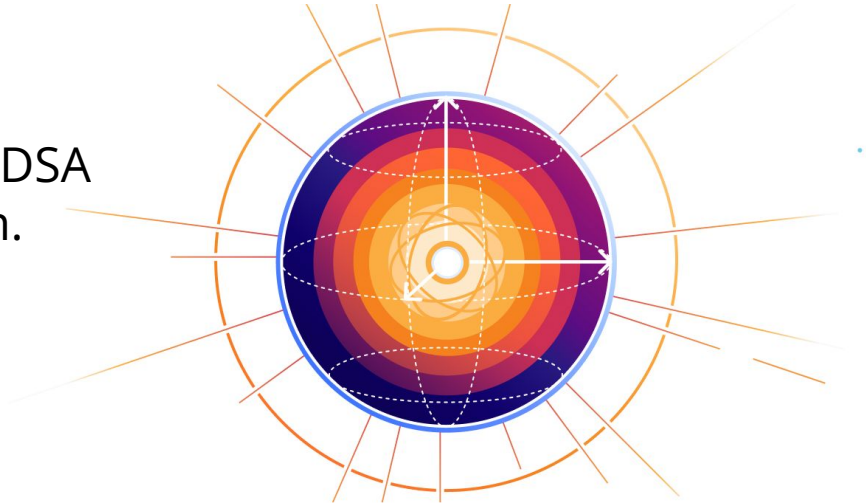
- Certificate issuance volume will go up 📈
- CT logs will log more entries 📈

Static CT *helps*, but there are still fundamental scaling issues

- Cert explosion: Each issued cert typically results in 10+ entries across logs 💥
- CT log consumers need to download *all* entries from *all* logs 🤯

The quantum threat

Quantum computers that break RSA and ECDSA are coming, but we don’t know exactly when.

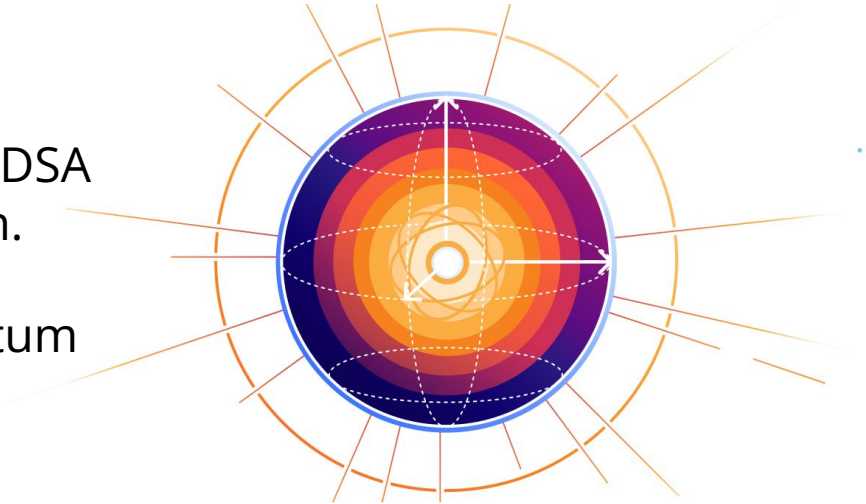


The quantum threat

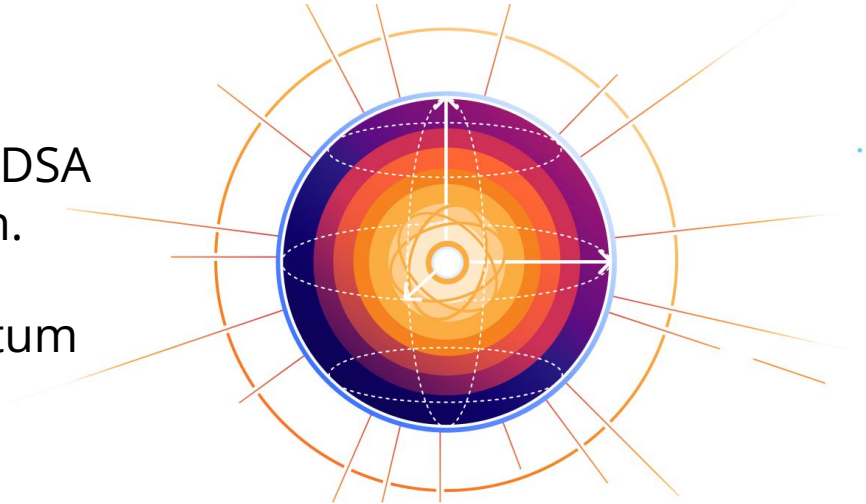
Quantum computers that break RSA and ECDSA are coming, but we don't know exactly when.

The good news: we already have post-quantum cryptography standards!

- For key agreement 🤝: ML-KEM already protects 65+% of non-bot requests to Cloudflare
- For signing 🖊️: ML-DSA, SLH-DSA (+more in the pipeline)



The quantum threat



Quantum computers that break RSA and ECDSA are coming, but we don't know exactly when.

The good news: we already have post-quantum cryptography standards!

- For key agreement 🤝: ML-KEM already protects 65+% of non-bot requests to Cloudflare
- For signing 🖊️: ML-DSA, SLH-DSA (+more in the pipeline)

The bad news: PQ signatures are big

- P-256 (ECDSA) keys are 64 bytes (uncompressed), and signatures 64 bytes
- ML-DSA-44 keys are 1,312 bytes (~20x), and signatures 2,420 bytes (~38x)

Post-quantum signatures are big

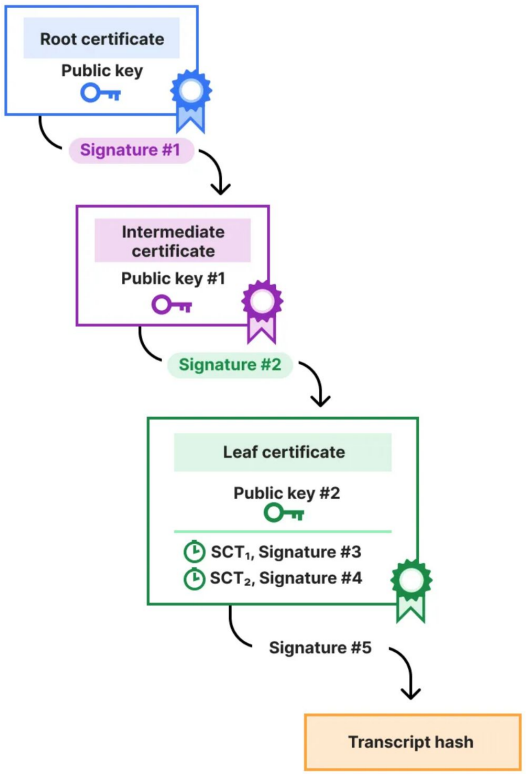
Impact on TLS

- Protocol designers have gotten addicted to small signatures

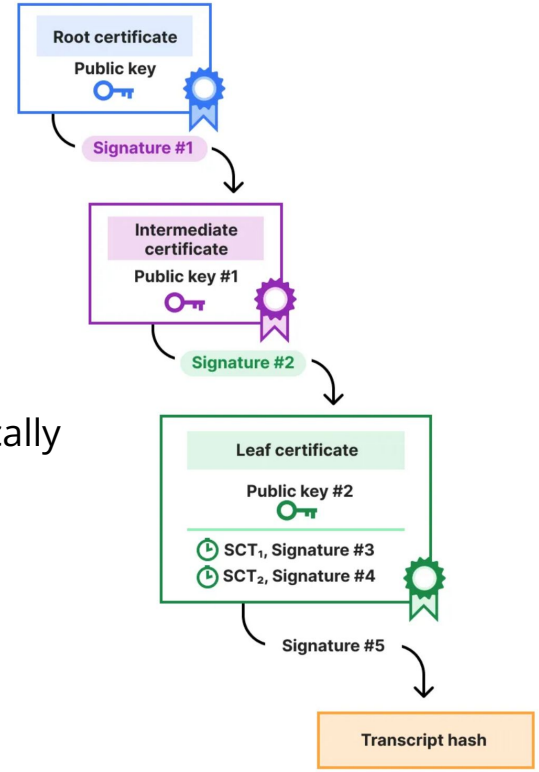
Post-quantum signatures are big

Impact on TLS

- Protocol designers have gotten addicted to small signatures
- A typical TLS handshake transmits 2 public keys and 5 signatures
  - With classical RSA and P-256, that's ~1.2kB
  - With ML-DSA-44 (best PQ option today) instead, that's ~14.7kB



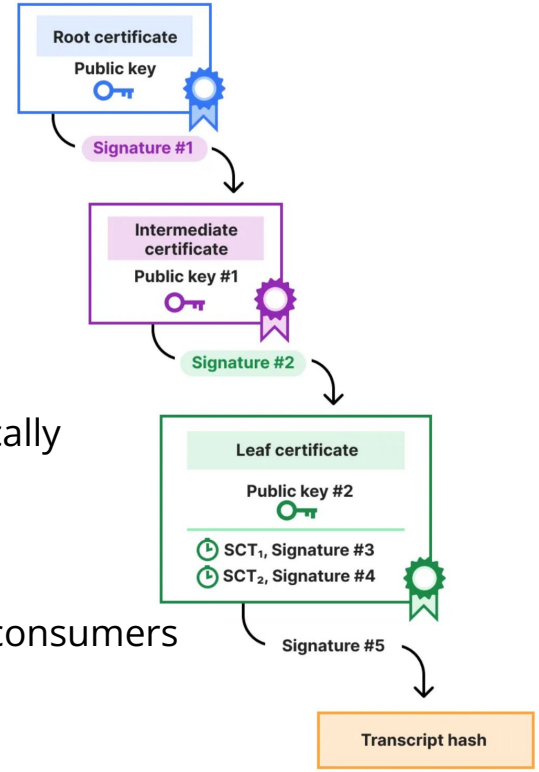
Post-quantum signatures are big



Impact on TLS

- Protocol designers have gotten addicted to small signatures
- A typical TLS handshake transmits 2 public keys and 5 signatures
  - With classical RSA and P-256, that's ~1.2kB
  - With ML-DSA-44 (best PQ option today) instead, that's ~14.7kB
- CF blog: ~1.5% slowdown per 1kB added to TLS handshake
- Chrome Security: "Adding ~7kB is implausible unless a cryptographically relevant quantum computer (CRQC) is tangibly imminent."

Post-quantum signatures are big



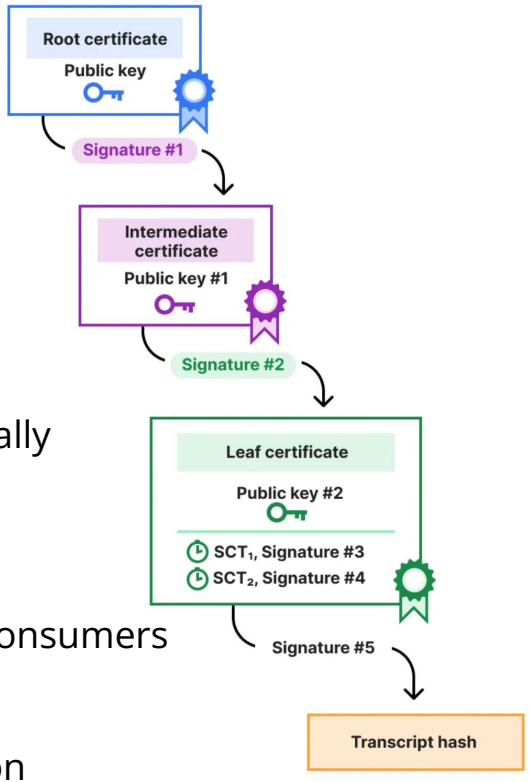
Impact on TLS

- Protocol designers have gotten addicted to small signatures
- A typical TLS handshake transmits 2 public keys and 5 signatures
  - With classical RSA and P-256, that's ~1.2kB
  - With ML-DSA-44 (best PQ option today) instead, that's ~14.7kB
- CF blog: ~1.5% slowdown per 1kB added to TLS handshake
- Chrome Security: "Adding ~7kB is implausible unless a cryptographically relevant quantum computer (CRQC) is tangibly imminent."

Impact on CT

- Bigger keys mean more data logged, more cost to CT log operators/consumers
- Per-entry signatures (SCTs) get more expensive

Post-quantum signatures are big



Impact on TLS

- Protocol designers have gotten addicted to small signatures
- A typical TLS handshake transmits 2 public keys and 5 signatures
  - With classical RSA and P-256, that's ~1.2kB
  - With ML-DSA-44 (best PQ option today) instead, that's ~14.7kB
- CF blog: ~1.5% slowdown per 1kB added to TLS handshake
- Chrome Security: "Adding ~7kB is implausible unless a cryptographically relevant quantum computer (CRQC) is tangibly imminent."

Impact on CT

- Bigger keys mean more data logged, more cost to CT log operators/consumers
- Per-entry signatures (SCTs) get more expensive
- Do we need to drop CT support?
  - Chrome Security: CT helps to detect downgrades in PQ transition

WebPKI needs a *repotting, not more patches

Newly-formed PLANTS (PKI, Logs, And Tree Signatures) working group at the IETF is working on it. (*“Come for the PQ PKI, stay for the 🪴 puns.”)

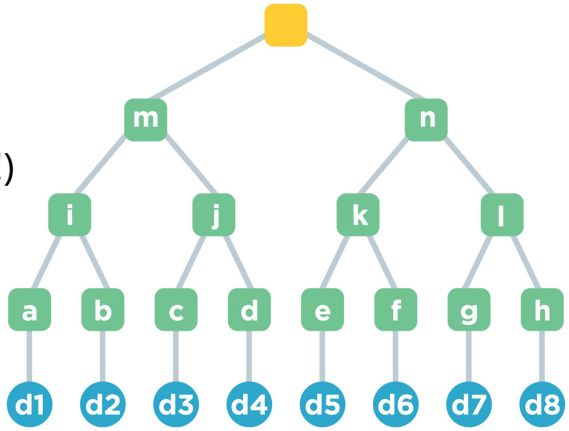
Goal: prune expensive PQ signatures from protocols like TLS, and build in transparency from the start.

First adopted work item is Merkle Tree Certificates (this talk).

Merkle Tree Certificates key ideas

“Don’t log what you issue, issue by logging”

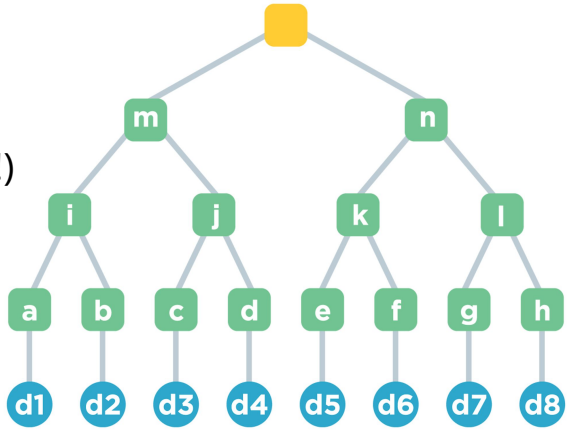
- CAs run their own issuance logs (bonus: nice incentive alignment!)



Merkle Tree Certificates key ideas

“Don’t log what you issue, issue by logging”

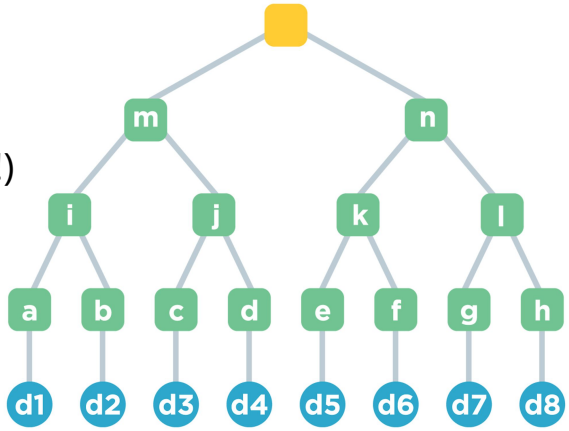
- CAs run their own issuance logs (bonus: nice incentive alignment!)
- Issue “domain ⇔ pubkey” claim by adding it to the log



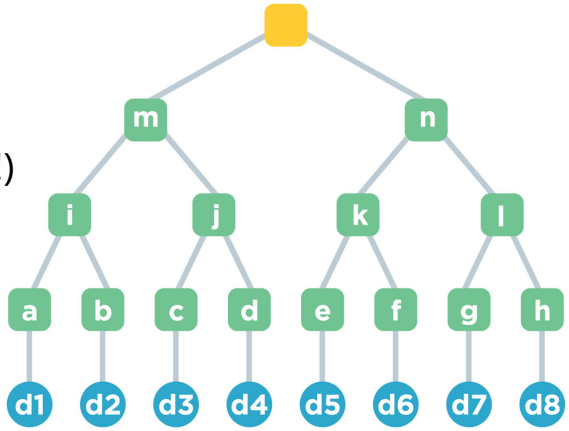
Merkle Tree Certificates key ideas

“Don’t log what you issue, issue by logging”

- CAs run their own issuance logs (bonus: nice incentive alignment!)
- Issue “domain ⇔ pubkey” claim by adding it to the log
- CA signature on “tree head” attest to *all* claims in the log
  - Independent cosigners keep CA honest



Merkle Tree Certificates key ideas



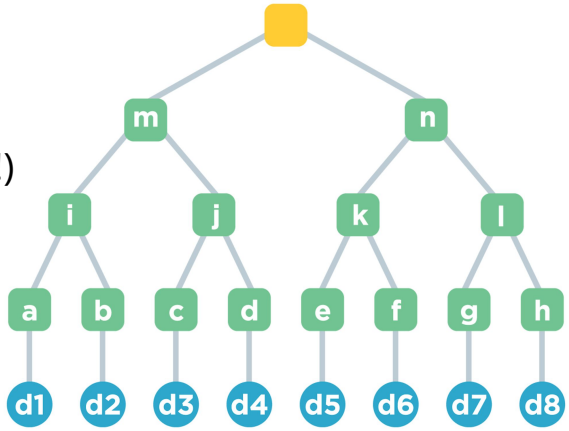
"Don't log what you issue, issue by logging"

- CAs run their own issuance logs (bonus: nice incentive alignment!)
- Issue "domain ⇔ pubkey" claim by adding it to the log
- CA signature on "tree head" attest to *all* claims in the log
  - Independent cosigners keep CA honest

Two types of MTC certificates

- Standalone — signature(s) on tree head + inclusion proof

Merkle Tree Certificates key ideas



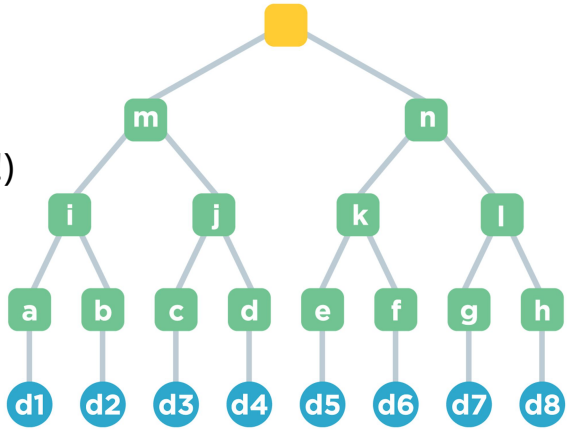
“Don’t log what you issue, issue by logging”

- CAs run their own issuance logs (bonus: nice incentive alignment!)
- Issue “domain ⇔ pubkey” claim by adding it to the log
- CA signature on “tree head” attest to *all* claims in the log
  - Independent cosigners keep CA honest

Two types of MTC certificates

- Standalone — signature(s) on tree head + inclusion proof
- Landmark — no signatures, only inclusion proof
  - Periodically (e.g., hourly), CA designates current tree head as a landmark
  - Landmarks tree heads are validated and distributed to clients out of band
  - For client with up-to-date tree heads, only need an inclusion proof to validate claim

Merkle Tree Certificates key ideas



“Don’t log what you issue, issue by logging”

- CAs run their own issuance logs (bonus: nice incentive alignment!)
- Issue “domain ⇔ pubkey” claim by adding it to the log
- CA signature on “tree head” attest to *all* claims in the log
  - Independent cosigners keep CA honest

Two types of MTC certificates

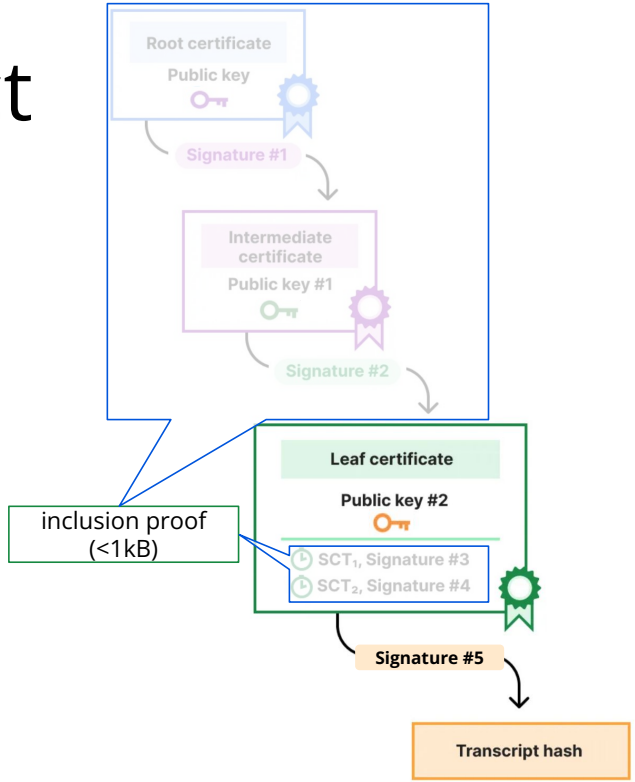
- Standalone — signature(s) on tree head + inclusion proof
- Landmark — no signatures, only inclusion proof
  - Periodically (e.g., hourly), CA designates current tree head as a landmark
  - Landmarks tree heads are validated and distributed to clients out of band
  - For client with up-to-date tree heads, only need an inclusion proof to validate claim

(Learn more in David Benjamin’s in-depth technical overview)

Merkle Tree Certificates impact

Impact on TLS

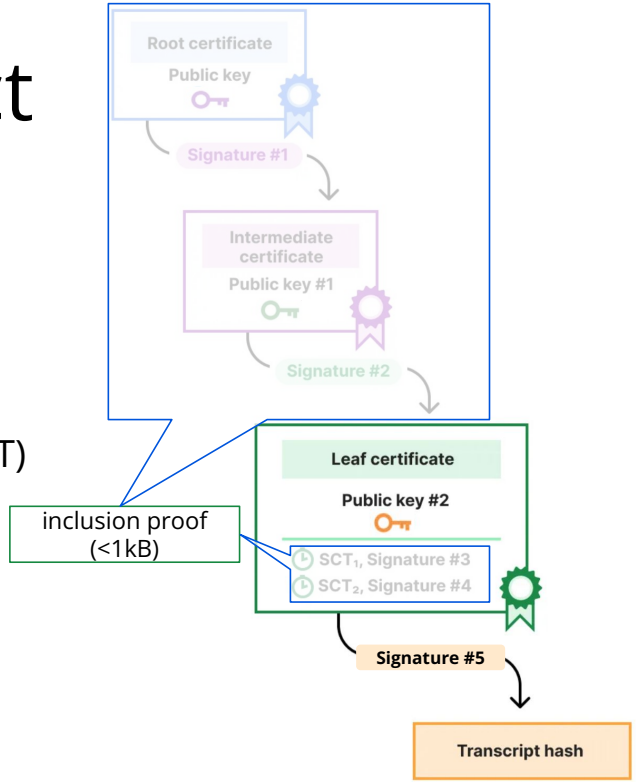
- With landmark certificate (common case), handshake transmits 1 public key, 1 signature, 1 inclusion proof (<1kB)



Merkle Tree Certificates impact

Impact on TLS

- With landmark certificate (common case), handshake transmits 1 public key, 1 signature, 1 inclusion proof (<1kB)
- With standalone certificate (fallback), handshake transmits 2-3 additional signatures (cost is closer to X.509 + CT)



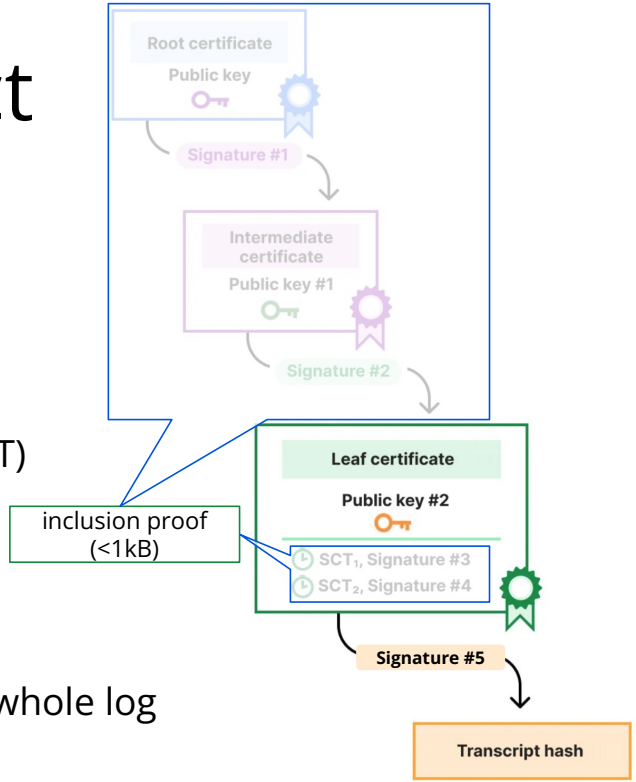
Merkle Tree Certificates impact

Impact on TLS

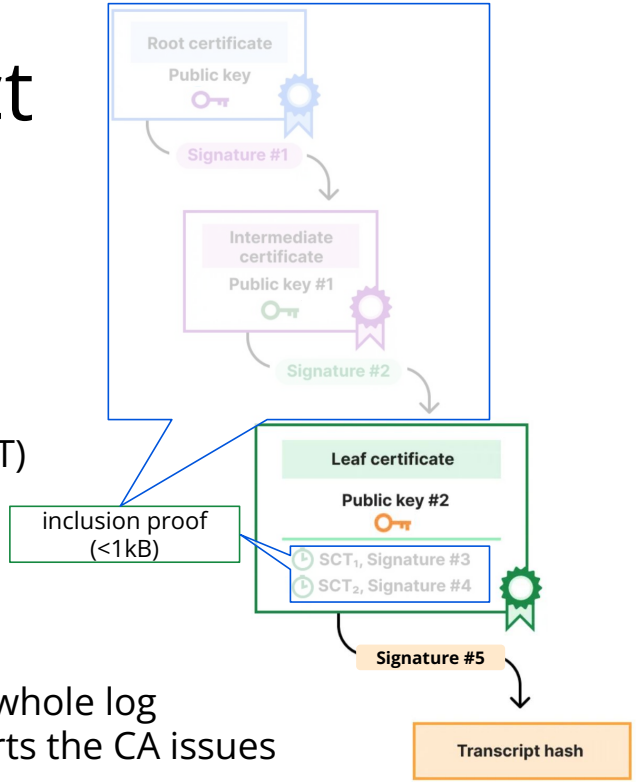
- With landmark certificate (common case), handshake transmits 1 public key, 1 signature, 1 inclusion proof (<1kB)
- With standalone certificate (fallback), handshake transmits 2-3 additional signatures (cost is closer to X.509 + CT)

Impact on CT

- *Don't pay the post-quantum tax*!
  - Log only public key hashes
  - No per-entry signatures; signature on tree head covers whole log



Merkle Tree Certificates impact



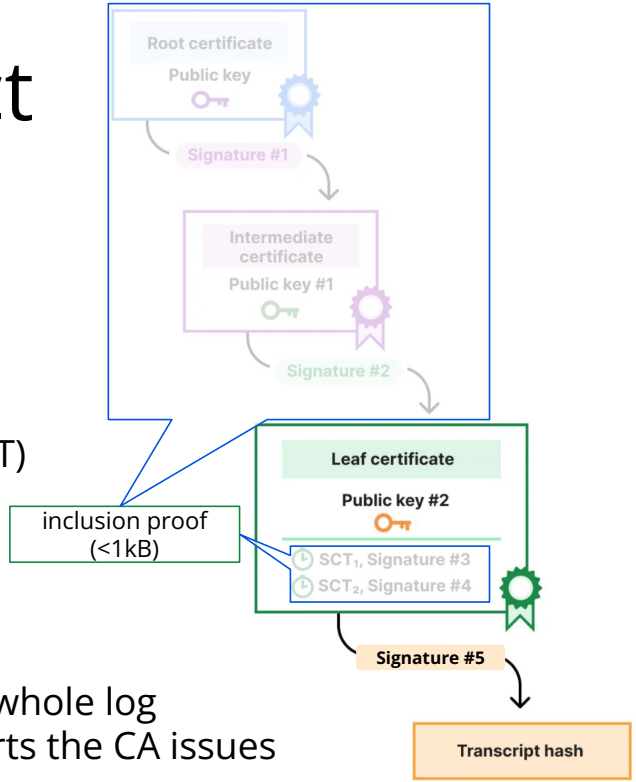
Impact on TLS

- With landmark certificate (common case), handshake transmits 1 public key, 1 signature, 1 inclusion proof (<1kB)
- With standalone certificate (fallback), handshake transmits 2-3 additional signatures (cost is closer to X.509 + CT)

Impact on CT

- *Don't pay the post-quantum tax*!
  - Log only public key hashes
  - No per-entry signatures; signature on tree head covers whole log
- No cert explosion; CA issuance log is source of truth for all certs the CA issues — log consumers only need to fetch a single copy of each cert

Merkle Tree Certificates impact



Impact on TLS

- With landmark certificate (common case), handshake transmits 1 public key, 1 signature, 1 inclusion proof (<1kB)
- With standalone certificate (fallback), handshake transmits 2-3 additional signatures (cost is closer to X.509 + CT)

Impact on CT

- *Don't pay the post-quantum tax*!
  - Log only public key hashes
  - No per-entry signatures; signature on tree head covers whole log
- No cert explosion; CA issuance log is source of truth for all certs the CA issues — log consumers only need to fetch a single copy of each cert
- CA issuance log implementation is very similar to that of Static CT logs

Merkle Tree Certificates experiment

Goal: evaluate feasibility and performance of MTCs

Merkle Tree Certificates experiment

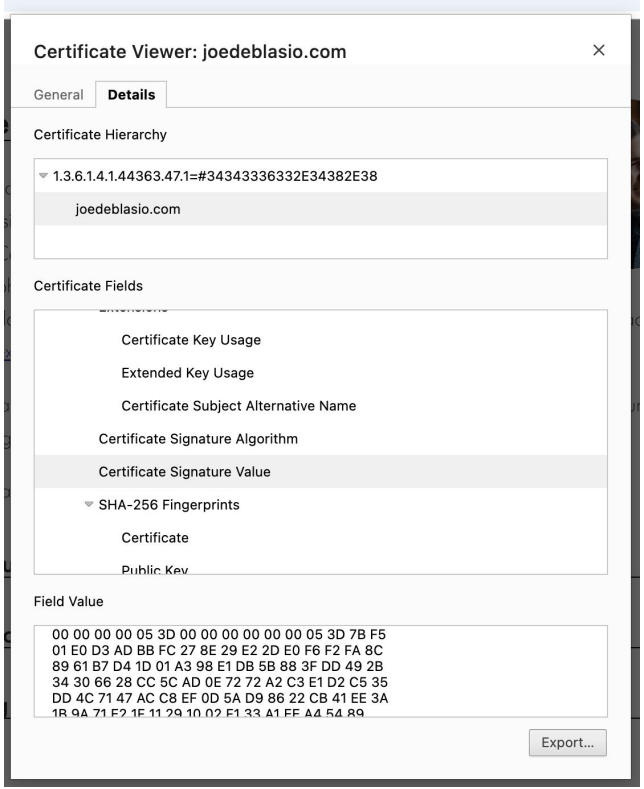
Goal: evaluate feasibility and performance of MTCs

Cloudflare runs

- TLS server — currently 1000 Cloudflare-proxied domains
- "bootstrap" MTC CA
  - Every MTC is backed by a traditional cert chain
  - Restricts experiment to classical signatures
- Limit to landmark MTCs

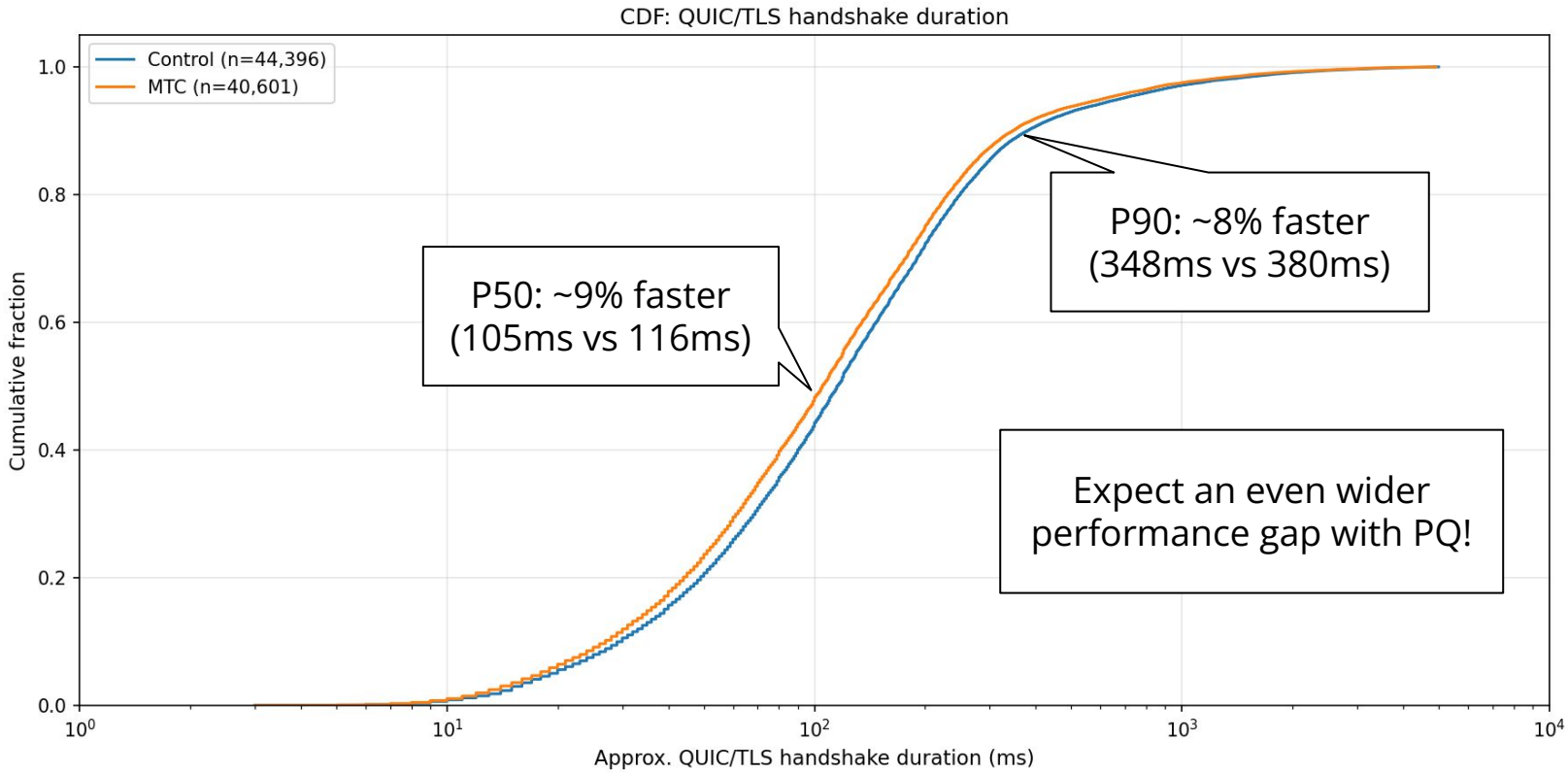
Chrome runs

- TLS client — currently 50% of Chrome Beta 146+
- Update service to validate and distribute landmarks

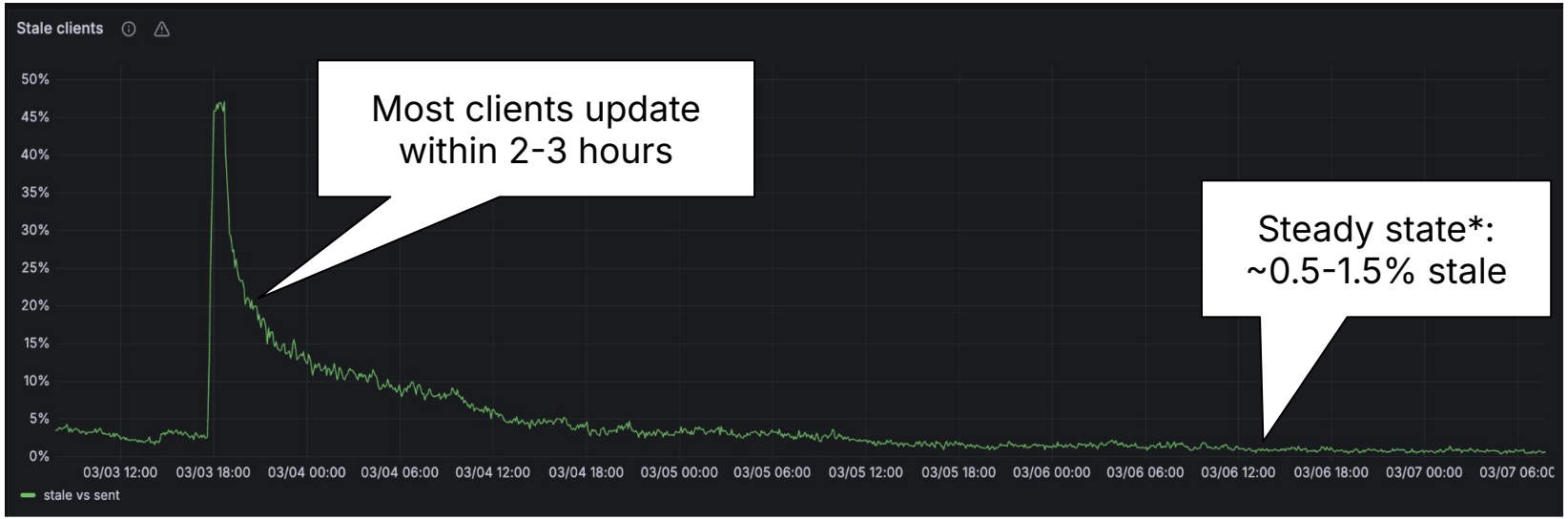


MTC in Chrome Beta

Are landmark MTCs faster than *classical*?



How quickly do clients get landmarks?



*This is an *upper bound* due to experimental quirks

What we've learned (so far)

MTCs work (!), and are used to secure real Internet traffic today.

What we've learned (so far)

MTCs work (!), and are used to secure real Internet traffic today.

How do MTCs perform?

- Significant latency improvements in TLS, *even over classical* signatures
- Generally not a problem for clients to stay up-to-date with landmarks

What we've learned (so far)

MTCs work (!), and are used to secure real Internet traffic today.

How do MTCs perform?

- Significant latency improvements in TLS, *even over classical* signatures
- Generally not a problem for clients to stay up-to-date with landmarks

Operational experience

- We've had to shake out a few bugs on both client and server side
- Middlebox interference thus far is a non-factor (TLS 1.3 encrypts server cert)

What’s next?

Experiment will continue to scale up — expect further blog posts.

What’s next?

Experiment will continue to scale up — expect further blog posts.

Industry/community support is picking up.

What’s next?

Experiment will continue to scale up — expect further blog posts.

Industry/community engagement is picking up.

How to get involved?

- Researchers, implementers, and protocol designers
  - Join PLANTS WG (March 16 @ IETF 125) — we need your input on open problems
    - Help tackle remaining spec work (ACME, revocation, log rotation)
  - Implement and cross-test to help build interoperability and find corner cases
- CA operators
  - Deploy experimental issuance systems — lettuce know what breaks

What’s next?

Experiment will continue to scale up — expect further blog posts.

Industry/community engagement is picking up.

How to get involved?

- Researchers, implementers, and protocol designers
  - Join PLANTS WG (March 16 @ IETF 125) — we need your input on open problems
    - Help tackle remaining spec work (ACME, revocation, log rotation)
  - Implement and cross-test to help build interoperability and find corner cases
- CA operators
  - Deploy experimental issuance systems — lettuce know what breaks

Questions?